



WEEK 2 DOCUMENTATION

1. ADVANCED THREAT ANALYSIS

STRIDE Threat Model (Web Application)

- Spoofing: User login page (Mitigation: Implement MFA)
- Tampering: HTTP Request parameters (Mitigation: Use HTTPS/TLS)
- Repudiation: Deleting access logs (Mitigation: Remote Logging)
- Information Disclosure: Database error messages (Mitigation: Custom Error Pages)
- Denial of Service: Flooding Port 80 (Mitigation: Rate Limiting)
- Elevation of Privilege: IDOR on Profile Page (Mitigation: Session Validation)

MITRE ATT&CK Mapping

- Tactic: Initial Access | Technique: T1566 (Phishing)
 - Tactic: Execution | Technique: T1059 (Command and Scripting Interpreter)
 - Tactic: Persistence | Technique: T1136 (Create Account)
-

2. SECURITY FRAMEWORKS IN DEPTH

NIST CSF Functions (WannaCry Case Study)

- Identify: Cataloged all systems using SMBv1 on Port 445.
- Protect: Blocked Port 445 and applied MS17-010 patch.
- Detect: Used IDS rules to monitor for EternalBlue exploit strings.
- Respond: Isolated infected hosts from the LAN immediately.
- Recover: Restored encrypted files from off-site cloud backups.

Risk Management (ALE Calculation)

- Scenario: Ransomware Attack
 - Single Loss Expectancy (SLE): \$10,000
 - Annual Rate of Occurrence (ARO): 0.2 (Once every 5 years)
 - Annual Loss Expectancy (ALE): \$2,000 (SLE x ARO)
-



3. PRACTICAL APPLICATION LABS

Task 1: Threat Hunting (Sigma Rule)

I created a Sigma rule to detect suspicious PowerShell command execution. Rule Title: Suspicious PowerShell Activity Logsource: Windows Process Creation Detection: CommandLine contains '-Command'

Task 2: Malware Analysis (Static)

Target: calc.exe Tool: strings / peframe Findings: Analysis showed imports for 'Kernel32.dll' and 'User32.dll'. No malicious C2 strings were found, confirming the file is a standard Windows utility.

Task 3: Vulnerability Management

Target: Metasploitable2 Tool: OpenVAS Top Priority Findings:

1. VSFTPD 2.3.4 Backdoor (Severity: 10.0)
2. Bind Shell on Port 1524 (Severity: 9.8)
3. Telnet Service Enabled (Severity: 7.5)

Task 4: Incident Response (Artifact Collection)

I used Velociraptor (simulated via native tools) to collect live system state.

- processes.csv (Process List)
- netstat.csv (Network Connections)

4. CAPSTONE PROJECT: FULL IR CYCLE

Phase 1: Attack Simulation

I used Metasploit to exploit the VSFTPD backdoor on Metasploitable2.

- Exploit: exploit/unix/ftp/vsftpd_234_backdoor
- Payload: cmd/unix/interact

Phase 2: Detection

The attack was monitored and flagged in the security console.



- Alert: VSFTPD exploit attempt detected.
- Mapping: MITRE T1190 (Exploit Public-Facing Application).

Phase 3: Containment & Recovery

I blocked the attacker IP using IPTables to stop the session. Command: `sudo iptables -A INPUT -s 192.168.60.128 -j DROP`